

无线通信安全第七讲作业

1.描述 AKA 协议，列出其安全目标，并分析其安全目标是否可以达到？

(1) AKA，即认证与密钥协商协议，是 WCDMA/3G 接入域安全中的核心协议。它运行在用户侧 USIM/ME、服务网络 VLR/SGSN 和归属网络 HE/HLR/AuC 之间。其基本思想是：USIM 与 AuC 预先共享用户唯一的长期秘密密钥 K，AuC 根据随机数 RAND、序列号 SQN、认证管理域 AMF 以及一组密码函数 $f_1 \sim f_5$ 生成认证向量 AV。认证向量包括 RAND、XRES、CK、IK 和 AUTN。服务网络把 RAND 和 AUTN 发给用户，USIM 验证 AUTN 中的 MAC 和 SQN 是否正确、新鲜；验证成功后计算 RES、CK 和 IK，并把 RES 返回服务网络。服务网络比较 RES 与 XRES，若一致，则完成用户认证，同时双方获得加密密钥 CK 和完整性密钥 IK。

(2) AKA 的安全目标：第一，实现用户和网络之间的双向认证，即用户确认网络是合法网络，网络也确认用户是合法用户；第二，生成用于空中接口加密的 CK，保证后续通信的机密性；第三，生成用于信令完整性保护的 IK，保证关键控制信令不被篡改；第四，保证 CK 和 IK 的新鲜性，即每次认证使用新的随机数和序列号，防止旧认证数据被重放使用。

(3) AKA 的主要安全目标基本可以达到。双向认证依靠 AUTN 中的 MAC 和用户返回的 RES/XRES 比较来完成，因此可以有效抵抗假基站攻击；CK 和 IK 不直接在无线信道上传输，而是由 USIM 和 AuC 分别计算得到，因此降低了密钥泄露风险；RAND 和 SQN 的变化保证密钥与 MAC 的新鲜性，可以抵抗重放攻击；SQN 还通过 AK 异或隐藏，减少暴露用户身份和位置信息的风险。不过，AKA 也不是完全没有缺陷，3G 仍然存在 IMSI 泄露、用户数据缺乏完整性保护、缺少端到端安全保护方法等问题。因此，AKA 能够较好实现“接入认证、密钥协商、防重放、防假基站”等目标，但不能单独解决所有隐私保护和端到端安全问题。

2.描述 WCDMA 系统在接入域中如何保证信息传输的机密性和完整性的。

WCDMA 接入域安全主要用于保证用户安全接入 3G 业务，并防止无线信道上的攻击。接入安全的内容包括用户身份机密性、用户位置机密性、用户不可跟踪性、用户身份认证、加密算法和完整性算法协商、加密密钥和完整性密钥协商，以及用户数据和信令数据的机密性与完整性保护。

(1) 在机密性方面，WCDMA 首先通过临时身份 TMSI/P-TMSI 来减少 IMSI 在无线信道上的明文暴露。通常用户在无线访问链路上使用 TMSI 与 LAI，或 P-TMSI 与 RAI 进行识别，只有在用户首次注册或网络无法由临时身份恢复 IMSI 时，才使用永久身份 IMSI。其次，系统通过 AKA 协议生成加密密钥 CK。完成认证后，UE 和 RNC 使用 CK 运行空口加密算法 f8，对用户业务信息和关键信令信息进行加密。f8 是序列密码机制，输入包括 CK、COUNT-C、BEARER、DIRECTION 和 LENGTH，输出密钥流，发送端用密钥流与明文异或得到密文，接收端再用同样密钥流恢复明文。这样可以防止攻击者在无线信道上直接窃听用户数据和重要信令。

(2) 在完整性方面，WCDMA 通过 AKA 协议生成完整性密钥 IK，并在 UE 和 RNC 中使用完整性算法 f9 来保护信令消息。f9 是由 IK 控制的单向函数，基于消息认证码 MAC 的思想。发送端输入 IK、COUNT-I、FRESH、MESSAGE 和 DIRECTION，计算出 MAC-I，并随信令消息发送；接收端使用相同参数计算 XMAC-I，并比较 MAC-I 与 XMAC-I 是否一致。如果一致，说明消息未被篡改且来源可信；如果不一致，则说明消息可能被伪造、修改或重放，应拒绝处理。除少数 12 种信令消息外，其他信令信息都需要完整性保护。

因此，WCDMA 接入域是通过“AKA 认证与密钥协商 + f8 加密机制 + f9 完整性机制 + 临时身份机制”共同保证信息传输安全的。AKA 负责认证和密钥产生，f8 负责机密性，f9 负责完整性，TMSI/P-TMSI 负责降低用户身份暴露风险。WCDMA 对用户数据主要提供机密性保护，而用户数据本身缺乏完整性保护，完整性保护主要用于信令数据。

3.举例解释下面名词：安全域、安全关联

(1) 安全域可以理解为在同一安全策略、管理规则和信任边界下的一组网络实体。3G 网络域安全中，其中 IP 核心网被划分为安全域 A 和安全域 B，每个安全域内部包含若干网元 NE 和安全网关 SEG。安全域内部的网元通常由同一运营商或同一管理系统管理，采用统一的安全策略；不同安全域之间则需要通过安全网关建立安全通道。例如，运营商 A 的核心网可以看作安全域 A，运营商 B 的核心网可以看作安全域 B。当 A 网中的网元需要与 B 网中的网元传输信令或数据时，二者不能简单认为彼此可信，而需要通过 SEG A 和 SEG B 之间的 IPsec 安全通道进行保护。

(2) 安全关联，简称 SA，是通信双方之间建立的一组安全参数和状态信息，用来规定双方如何进行安全通信。SA 用于定义安全通信所采用的加密算法、完整性算法、密钥及相关安全属性。例如，在 MAPsec 中，一个安全关联可以由目标 PLMN ID 和 SPI 唯一确定，其中包含发送 PLMN ID、MAP 加密密钥 MEK、MAP 加密算法标识 MEA、MAP 完整性密钥 MIK、MAP 完整性算法标识 MIA、保护轮廓 ID、软有效时间和硬有效时间等信息。也就是说，SA 就像通信双方事先约定好的一份“安全通信合同”：用什么算法、用哪把密钥、保护多久、如何识别这条安全连接，都由 SA 来规定。

举例来说，如果 PLMN A 中的网元要向 PLMN B 中的网元发送 MAP 信令消息，可以先根据目标 PLMN ID 和 SPI 找到对应的 MAPsec 安全关联。若该 SA 指定保护模式 2，则发送方要先用 MEK 对 MAP 消息加密，再用 MIK 计算 MAC；接收方则根据同一个 SA 找到对应算法和密钥，先验证 MAC，再解密消息。这样，SA 就把一次安全通信所需的算法、密钥、保护模式和生命周期统一管理起来。